



Análisis de Informe de Incidente - Ejemplo

Resumen	Esta mañana, una pasante informó al departamento de TI que no podía iniciar sesión en su cuenta de la red interna. Los registros de acceso indican que su cuenta ha estado accediendo activamente a registros de la base de datos de clientes, a pesar de que tiene bloqueado el acceso a esa cuenta. La pasante indicó que esta mañana recibió un e-mail pidiéndole que se dirigiera a una web externa para iniciar sesión con sus credenciales de la red interna y así recuperar un mensaje. Creemos que este fue el método utilizado por un actor malicioso para obtener acceso a nuestra red y a la base de datos de clientes. Otros empleados notaron que varios registros de clientes faltan o contienen datos incorrectos. Parece que los datos de los clientes no solo quedaron expuestos a un actor malicioso, sino que además algunos datos fueron eliminados o manipulados.
Identificar	El equipo de gestión de incidentes auditó los sistemas, dispositivos y políticas de acceso involucrados en el ataque para identificar las brechas de seguridad. El equipo descubrió que un atacante obtuvo el usuario y la contraseña de una pasante, y los usó para acceder a los datos de nuestra base de datos de clientes. Tras una revisión inicial, parece que se eliminaron algunos datos de clientes de la base de datos.
Proteger	El equipo implementó nuevas políticas de autenticación para prevenir futuros ataques: autenticación multifactor (MFA), un límite de tres intentos de inicio de sesión y capacitación para todos los empleados sobre cómo proteger sus credenciales de acceso. Además, implementaremos una nueva configuración de firewall de protección e invertiremos en un sistema de prevención de intrusiones (IPS).

Detectar	Para detectar nuevos intentos de acceso no autorizado en el futuro, el equipo utilizará una herramienta de registro del firewall y un sistema de detección de intrusiones (IDS) para monitorear todo el tráfico entrante desde internet.
Responder	El equipo deshabilitó la cuenta de red de la pasante. Brindamos capacitación de inducción a nuevos empleados sobre cómo proteger las credenciales de acceso en el futuro. Informamos de este evento a la gerencia, quienes se pondrán en contacto con nuestros clientes por correo postal para informarles sobre la filtración de datos. La gerencia también deberá informar a las autoridades y a otras organizaciones.
Recuperar	El equipo recuperará los datos eliminados restaurando la base de datos a partir de la copia de seguridad completa de anoche. Hemos informado al personal que cualquier información de clientes ingresada o modificada esta mañana no quedará registrada en esa copia de seguridad. Por lo tanto, deberán volver a ingresar esa información en la base de datos una vez que se haya restaurado a partir de la copia de seguridad de anoche.

Reflexiones/Notas: Este incidente demuestra cómo un ataque de phishing puede comprometer la seguridad de una organización a partir del robo de las credenciales de un único usuario. El acceso no autorizado afectó la confidencialidad y la integridad de los datos de los clientes, ya que la información fue expuesta, modificada y eliminada.

Considero que una de las principales debilidades fue depender únicamente de usuario y contraseña para la autenticación. La implementación de MFA, junto con la capacitación de los empleados para reconocer intentos de phishing, podría reducir significativamente este riesgo.

También considero importante complementar las medidas preventivas con controles de detección y monitoreo. El uso de registros de acceso, IDS y alertas ante comportamientos inusuales permitiría identificar más rápidamente una cuenta comprometida y reducir el impacto del incidente.

Este caso me permitió comprender que la respuesta ante un incidente no consiste solamente en detener el ataque, sino también en identificar su origen, contenerlo, recuperar los sistemas afectados y aplicar mejoras que reduzcan la posibilidad de que vuelva a ocurrir.

